POLITICA DE SEGURIDAD PARA LA EMPRESA

Título de la Norma	Política de seguridad para la empresa
Ámbito	Responsable
Categoría	Política
Responsable	Gerencia
Fecha de aprobación	24/11/2022
Versión	1.0

NGORONG SL
PARTIDA VALLONGAS, P.1, 35 - 03295 ELCHE (Alacant)

1. ÁMBITO DE APLICACIÓN

Está política de seguridad aplica al responsable de la empresa NGORONG SL en adelante el “Responsable” con la finalidad de tener en cuenta en todos los procesos de la organización, las medidas de seguridad en materia de protección de datos

Asimismo, el Responsable está comprometido en implantar una cultura de privacidad en la organización, por lo que necesita que las personas autorizadas a tratar datos personales estén informadas del tratamiento de datos y se responsabilicen del mismo. Por tal motivo, se elabora y se entrega la política de seguridad del personal para que lean y entienda las medidas a seguir en materia de protección de datos.

2. ALCANCE

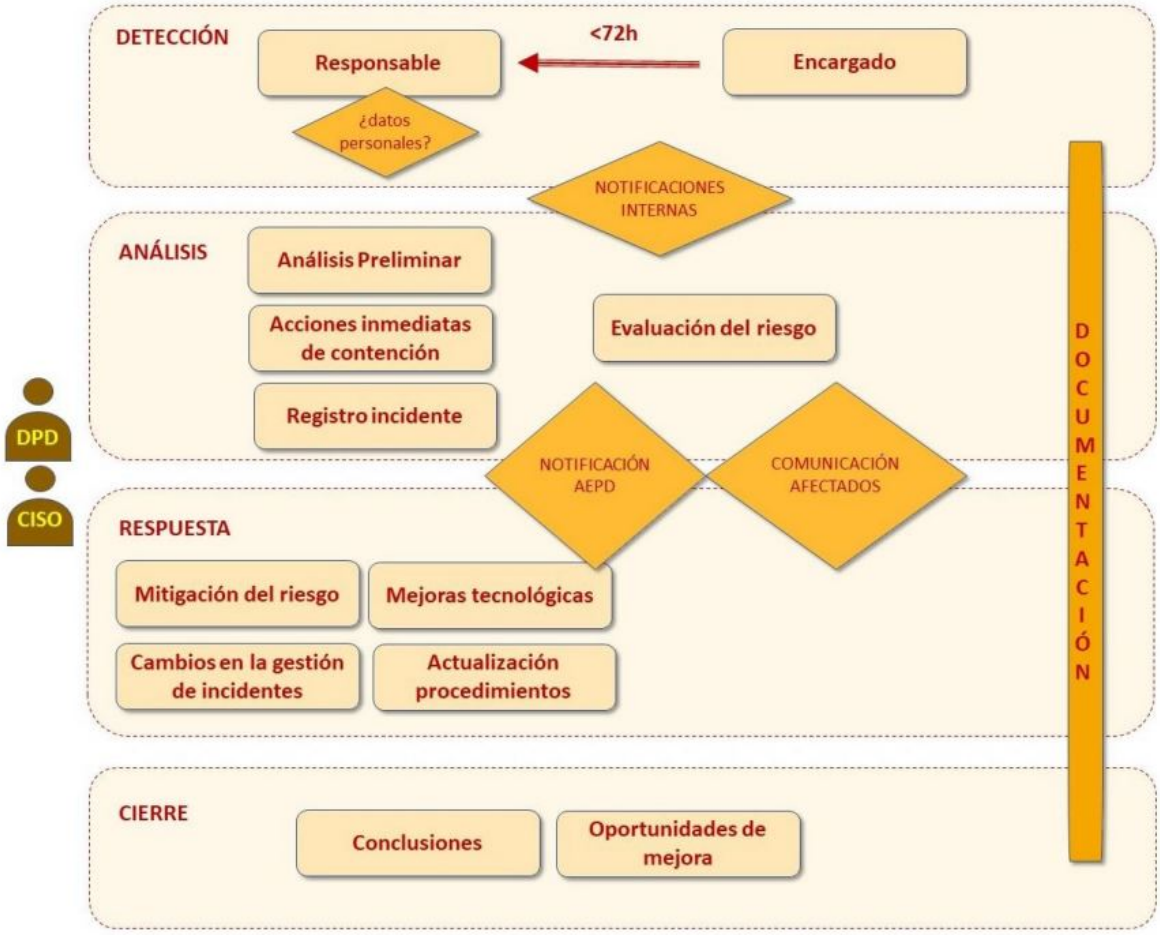
Definir el procedimiento a seguir en la trazabilidad de datos de carácter personal.

3. CONCEPTOS BÁSICOS

Para una mejor comprensión se define los principales conceptos:

- **Datos personales**: Información relativa a una persona física por la cual pueda determinarse su identidad.
- **Tratamiento**: Cualquier operación realizada sobre datos personales: obtención, acceso, intervención, transmisión, conservación y supresión.
- **Interesado**: Persona física sometida al tratamiento de sus datos personales.
- **Fichero**: Conjunto estructurado de datos personales susceptibles de tratamiento para un fin determinado.
- **Responsable del tratamiento**: Organización que determina los fines y los medios del tratamiento.
- **Personal autorizado**: Persona autorizada por el Responsable para realizar un tratamiento de datos mediante un compromiso de confidencialidad.
- **Encargado de tratamiento**: persona física o jurídica, que trate datos personales por cuenta del responsable del tratamiento.
- **Brecha de seguridad:** cualquier violación de la seguridad que ocasione la destrucción accidental o ilícita, pérdida, alteración, o el acceso o comunicación no autorizados de datos personales

NGORONG SL
PARTIDA VALLONGAS, P.1, 35 - 03295 ELCHE (Alacant)



4. FUNCIONES Y OBLIGACIONES

Organización de la información

El Responsable deberá clasificar los datos de manera que se puedan ejercer los derechos de los interesados: acceso, rectificación, supresión y portabilidad de los datos y limitación u oposición al tratamiento.

Conservación de los datos

El Responsable deberá conservar los datos en el mobiliario y departamento destinados a tal fin, con las medidas de seguridad adecuadas. Para tratamientos automatizados se guardarán los archivos en los soportes, carpetas o directorio de red con medidas de seguridad adecuadas(ciberseguridad).

Acceso a la información

Se deberán aplicar los mecanismos de acceso restringido a la información, y salvaguardar las claves de acceso de toda divulgación o comunicación a otras personas

Se restringirá el acceso a los equipos informáticos mediante procedimientos que puedan identificar y

autenticar la persona que accede a los mismos. Los nombres de usuario y contraseña tendrán la consideración de datos personales intransferibles.

Procesamiento de datos

Los soportes documentales e informáticos deberán estar dispuestos de tal forma que no sean accesibles a personas no autorizadas.

Se debe informar al personal de: si una persona abandona su puesto de trabajo temporalmente, deberá ocultar los documentos y bloquear el ordenador, de modo que se impida la visualización de la información con la que estaba trabajando.

Se debe informar al personal de cuando se utilicen impresoras o fotocopiadoras, después de la impresión de trabajos con información de carácter personal, se debe recoger de manera inmediata, o imprimir de forma bloqueada, asegurándose de no dejar documentos impresos en la bandeja de salida.

Transporte de soportes

El transporte de soportes que contengan datos personales deberá realizarse únicamente por personal autorizado o empresas externas contratadas para tal fin.

Eliminación de documentos

Cualquier documento físico o soporte digital que quiera ser eliminado y que incluya datos personales, debe ser destruido con la destructora o retirado por una empresa homologada de destrucción de documentos.

Copia de seguridad y recuperación de datos.

El responsable deberá tener un Plan de Contingencia y Continuidad de Negocio para responder de manera rápida y eficaz ante un incidente de seguridad, porque la pérdida de esta información supondría la pérdida de horas de trabajo y de proyectos que tendría graves consecuencias para la continuidad del negocio.

Protección de datos en general

Se deberán aplicar las medidas de protección de datos establecidas por la organización relativas a la seguridad del tratamiento como pueden ser la seudonimización o cifrado de datos o advertencias de intrusión como antivirus, antispam, etc.

5. PROCEDIMIENTO TRAZABILIDAD DE DATOS

Curriculum: el responsable o el personal designado deberá informar y solicitar el consentimiento del interesado.

Contrato del personal: 1.- el Responsable debe entregar toda la documentación en materia de protección de datos, por tal motivo se debe poner en contacto con Zenit consultores Levante con la finalidad de facilitarle dicha documentación. **2.-**El responsable debe entregar la Política de Seguridad al personal contratado y asegurarse que lean y entienda su contenido.

NGORONG SL
PARTIDA VALLONGAS, P.1, 35 - 03295 ELCHE (Alacant)

Contrato Proveedores: 1.- se deberá escoger únicamente a un Encargado que ofrezca garantías suficientes para aplicar medidas técnicas y organizativas apropiadas en materia de protección de datos. **2.-** se debe firmar con el Encargado un contrato de confidencialidad, por tal motivo se debe poner en contacto con Zenit consultores Levante con la finalidad de facilitarle dicha documentación.

Compra de dispositivos, software, o armario: se deberá tener en cuenta desde el diseño y por defecto los riesgos de diversa probabilidad y gravedad que entrañan el tratamiento de datos, con la finalidad de evitar posibles incidencias que entrañen vulneración de los derechos y libertades fundamentales de las personas físicas. Si tiene alguna duda, ponerse en contacto con Zenit Consultores Levante

- **Control software malicioso se debe configurar las herramientas de detección de software malicioso.** Para un uso eficiente de las herramientas de control de malware se debe realizar una correcta configuración de todas sus funcionalidades.

  La configuración deberá permitirnos, entre otros, establecer los siguientes controles:

  - realizar análisis automáticos y periódicos para detectar malware;
  - realizar comprobaciones automáticas de los ficheros adjuntos al correo y de las descargas web, ya que pueden contener código malicioso ejecutable;
  - bloquear el acceso a ciertas aplicaciones o sitios web basándonos en una política de listas negras;
  - permitir el acceso a ciertas aplicaciones o sitios web basándonos en una política de listas blancas;
  - permitir el análisis de páginas web para detectar posibles amenazas incluidas en las mismas.

- **Actualizar las herramientas de detección de malware.** Debemos determinar la periodicidad con la que las herramientas de detección de malware son actualizadas. Actualmente se crean miles de virus al día, por lo que las actualizaciones de la base de datos de firmas de virus deberían ser automáticas y tener una periodicidad como mínimo diaria. Por otro lado, y como cualquier otra aplicación crítica, se tendrá que actualizar convenientemente el propio software antivirus.

El Responsable deberá informar al personal de su obligación de velar por la seguridad de los datos tratados por la organización y comunicará al Responsable cualquier operación de tratamiento que pueda suponer un riesgo que afecte la protección de datos o los intereses y libertades de los interesados.

Configuración de equipos: se deberá tener en cuenta todas las medidas de seguridad posibles en el momento de cambiar o comprar algún dispositivo informático, por tal motivo de deberá poner en contacto con su servicio de informática para ayudarle en la implantación en las medidas de seguridad (ciberseguridad). Entre ellos tenemos:

- Control de acceso personal autorizado
- Cambiar la contraseña de acceso al router
- Modificar el nombre de la red wifi
- Contraseña Robusta de acceso a la red wifi
- Actualización del Firmware cada vez que haya una nueva versión disponible

NGORONG SL
PARTIDA VALLONGAS, P.1, 35 - 03295 ELCHE (Alacant)

- Red wifi para invitados separada de la red local
- Apagar el router En los horarios en que no vayas a utilizar tu conexión a Internet.
- …etc

Copias de seguridad El responsable debe tener un Plan de Contingencia y Continuidad de Negocio para responder de manera rápida y eficaz ante un incidente de seguridad. Hay que tener en cuenta que los soportes donde se recoge la información suelen tener una vida útil limitada (averías, desgastes…) y están sujetos a diversos riesgos y/o amenazas (accidentes, ataques...). Por estos motivos el Responsable debe implementar las medidas para proteger el mayor activo que almacenamos en dichos soportes, la información. Entre ellos tenemos:

- Copias de seguridad basadas en discos duros pueden realizarse en dispositivos NAS
- En la nube
- Soluciones mixtas
- …etc

Una buena práctica a la hora de realizar copias de seguridad: es adoptar la estrategia 3-2-1 que se basa en diversificar las copias de seguridad para garantizar que siempre haya alguna recuperable. Sus claves de actuación son las siguientes :

- 3: Mantener 3 copias de cualquier fichero importante: el archivo original y 2 backups.
- 2: Almacenar las copias en 2 soportes distintos de almacenamiento para protegerlas ante distintos riesgos. Si tuviéramos las dos copias en el mismo tipo de soporte, ambos pueden verse afectados por el mismo fallo de funcionamiento y por tanto poner en peligro las dos copias al mismo tiempo.
- 1: Almacenar 1 copia de seguridad fuera de nuestra empresa, lo que también se conoce como backup offsite.

Ubicación de las copias de seguridad:

- contar con al menos una copia fuera de la organización;
- valorar la contratación de servicios de guarda y custodia si se considera necesario por motivos de seguridad física

Cifrado de las copias de seguridad:

El responsable debe garantizar la confidencialidad e integridad de la información sensible cuando está almacenada, utilizaremos herramientas de cifrado que protejan nuestros datos, haciéndolos ilegibles por aquellos que no dispongan de la clave de cifrado. Cifrando la información confidencial y la almacenada en copias de seguridad protegemos los datos en caso de robo de información o accesos no autorizados, reduce el riesgo de sanciones y podría evitar, que tengamos que informar a los usuarios en caso de brecha de seguridad. Además, se cumplirá con el deber de salvaguarda que exige el Reglamento General de Protección de datos.

Entrega de equipos informáticos:

En caso de entrega de algún equipo informativo tales como portátiles, Tablet, moviles al personal de la empresa, el Responsable deberá entregar el anexo de entrega del equipo: con el tipo, marca y serial del

NGORONG SL
PARTIDA VALLONGAS, P.1, 35 - 03295 ELCHE (Alacant)

mismo, para firmar por el trabajador/a, tanto la entrega como su devolución. Es importante resaltar que la organización tiene que hacer hincapié en que el personal lea y entienda la política de seguridad del personal, donde estable la medida de técnicas para su utilización.

Contraseñas

Para garantizar que las contraseñas se generan y usan de forma robusta, pueden ayudarse de diversas herramientas como LDAP, Active Directory o servicios externos que obligan al cumplimiento de ciertos requisitos. En todos los casos se contemplarán los aspectos más relevantes como:

- periodos de validez para las contraseñas;
- posibilidad de no reutilización de contraseñas ya usadas;
- formato de la contraseña: longitud mínima, tipos de caracteres que deben incluir y cumplimiento de reglas semánticas.
- posibilidad de elección y modificación de la contraseña por parte del usuario;
- almacenamiento de las claves: tamaño del histórico de claves a almacenar para cada usuario;
- método de encriptación de las claves y número de intentos de autenticación permitidos.

No utilizar las contraseñas por . las siguientes directrices:

- deben contener al menos 8 caracteres;
- deben combinar caracteres de distinto tipo (mayúsculas, minúsculas, números y símbolos como @, #, $, etc.);
- no deben contener los siguientes tipos de palabras: palabras sencillas en cualquier idioma (palabras de diccionarios); nombres propios, fechas, lugares o datos de carácter personal como la fecha de cumpleaños; palabras que estén formadas por caracteres próximos en el teclado o palabras excesivamente cortas.
- tampoco utilizaremos claves formadas únicamente por elementos o palabras que puedan ser públicas o fácilmente adivinables (ej. nombre + fecha de nacimiento);
- se establecerán contraseñas más fuertes para el acceso a aquellos servicios o aplicaciones más críticas;

No utilizar la misma contraseña para servicios diferentes: Nunca se debe utilizar la misma contraseña para diferentes servicios. Tampoco utilizaremos las mismas contraseñas para uso profesional y doméstico. De esta forma evitaremos tener que cambiar todas nuestras contraseñas en el caso de que solo una haya sido comprometida.

Cambiar las contraseñas periódicamente: Para garantizar la confidencialidad de las contraseñas estas deben ser cambiadas periódicamente. La periodicidad dependerá de la criticidad de la información a la que dan acceso. No deben utilizarse contraseñas que hayan sido usadas con anterioridad. Pueden utilizarse sistemas que fuercen al cambio de contraseña en el plazo elegido.

NGORONG SL
PARTIDA VALLONGAS, P.1, 35 - 03295 ELCHE (Alacant)

No hacer uso del recordatorio de contraseñas: No es recomendable el utilizar las funcionalidades de recordatorio de contraseñas, ya que pueden facilitar el acceso a personal no autorizado.

Auditorías. Conviene realizar periódicamente auditorías de seguridad que certifiquen que se aplican los tratamientos estipulados para proteger nuestra información.

6.- MARCO NORMATIVO

La protección de las personas físicas, en relación con el tratamiento de datos personales, es un derecho fundamental protegido por el artículo 18.4 de la Constitución española «la ley limitará el uso de la informática para garantizar el honor y la intimidad personal y familiar de los ciudadanos y el pleno ejercicio de sus derechos»

Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (LOPDGDD)

Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de sus datos personales y a la libre circulación de estos datos, conocido por las siglas RGPD.

NGORONG SL
PARTIDA VALLONGAS, P.1, 35 - 03295 ELCHE (Alacant)